

Reference Architecture for Securing Data Flows Across Enterprise AI Systems Consuming LLMs

Shittu Shittu

Global Chief Security Architect

PricewaterhouseCoopers LLP

October 25, 2025

Abstract

Organisations increasingly consume large language model (LLM) capabilities rather than building or training their own models. This paper proposes a practical, capability-based reference architecture for securing end-to-end data flows across three dominant consumption patterns: locally installed LLM runtimes on endpoints, hosted LLMs in a cloud tenant (for example, Azure OpenAI), and enterprise SaaS LLMs (for example, ChatGPT Enterprise). The architecture centers on zero-trust principles, strong identity, data-centric security, secure mediation of agent and tool interactions via the Model Context Protocol (MCP) and enterprise APIs, and continuous assurance. We map controls to critical data paths in knowledge from enterprise resources, orchestration gateways, and MCP-enabled agent workflows. The approach aligns with NIST AI RMF and generative AI security guidance, including OWASP Top 10 for LLM Applications (2025), and distills actionable patterns, anti-patterns, and an implementation roadmap for security architects and platform teams.

Disclaimer: *The views and opinions expressed in this paper are solely those of the author and do not necessarily reflect the official policy or position of the author's employer.*

1. Introduction and Problem Statement

Enterprises adopt LLMs to augment knowledge work, automate workflows, and improve customer and employee experiences. Most organisations *consume* LLMs via one or more of the following:

- Local LLM runtimes on enterprise endpoints (privacy, latency, offline use). An endpoint-resident (for example, Llama2, Mistral, or Claude-instant) interacts with local tools and a local vector store, while accessing enterprise APIs through a managed proxy.
- Hosted LLMs within a cloud provider tenancy (for example, Azure OpenAI)
- Enterprise SaaS LLMs (for example, ChatGPT Enterprise)

Representative patterns

Extensions of the above consumption patterns include LLM-powered agents and multi-agent systems that autonomously interact with enterprise data and systems via tools, APIs, and the Model Context Protocol (MCP) [7,8,10,23,26,27]. These agents, and MCP servers, may operate within any of the three consumption models, creating complex data flows and trust boundaries.

- **On enterprise endpoints:** An endpoint-resident AI Agent (for example, Cursor, Claude Code, or Cline); a local MCP server that brokers tool calls via stdio
- **Enterprise Cloud tenancy (for example, Azure OpenAI):** Hosted Agentic App or AI Agent, Hosted MCP server
- **Third-party or SaaS:** Sanctioned and unsanctioned third-party / SaaS Agent and/or MCP server

Figure 1 illustrates representative data flows for the consumption patterns, highlighting key interfaces where LLMs interact with enterprise data and systems.

The data flows fall into one or combination of the following:

- Browser to LLM Web App: over HTTP/s. See Figure 2
- Non-browser to other web services: over HTTP/s. See Figure 3
- Local Agent to local MCP server: JSON RPC over stdio. See Figure 4
- Any Agent to any MCP server: JSON RPC over HTTP/s. See Figure 5
- Any MCP server to Tools: APIs over HTTP/s. See Figure 6
- Agent to Agent: various interop protocols (A2A, custom). See Section 7

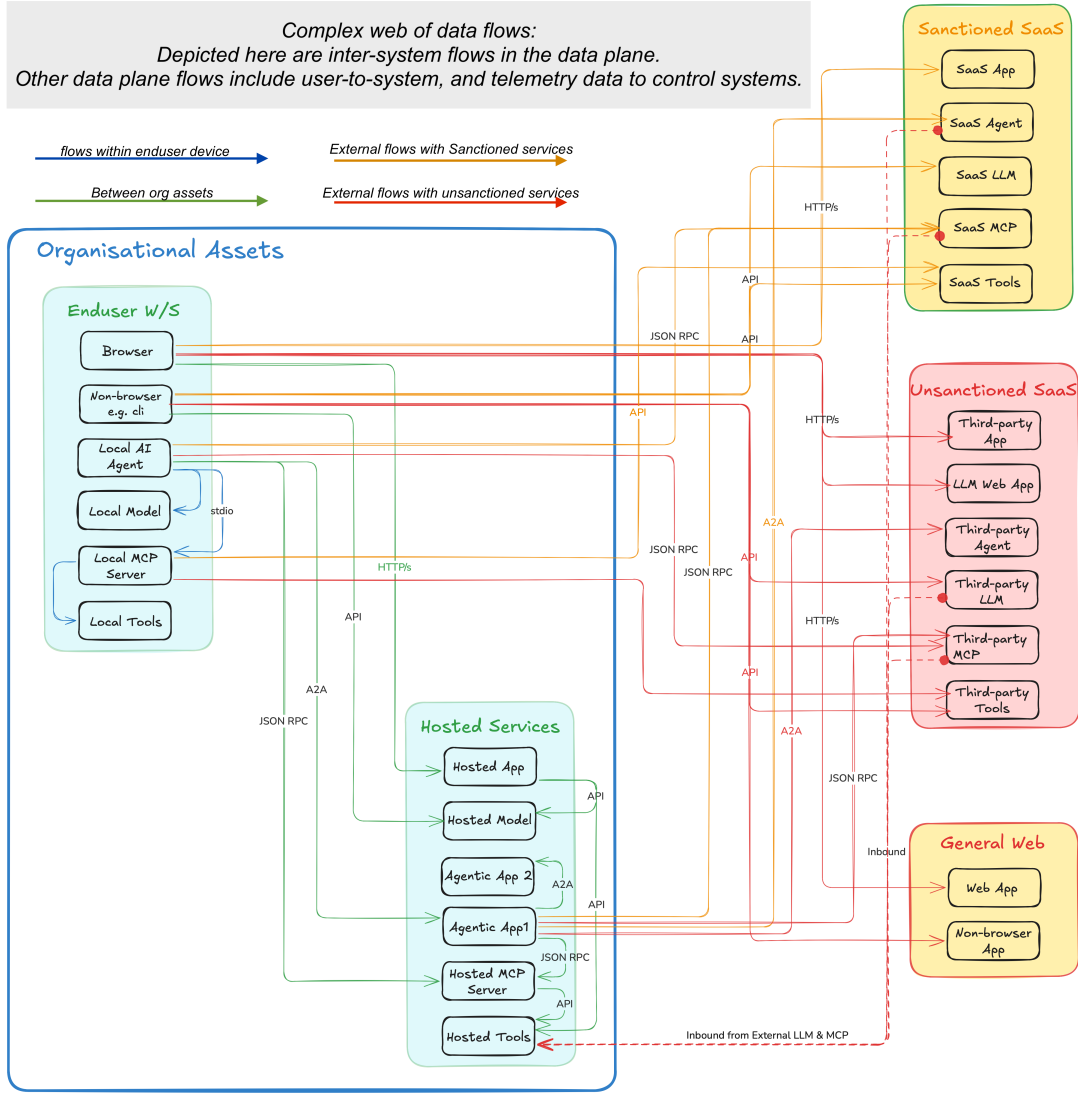


Figure 1: Representative data flows for local LLMs, hosted LLMs, and enterprise SaaS LLMs. Key interfaces where LLMs, agents and MCP servers interact with enterprise data and systems are depicted.

Security challenges arise where LLMs interface with enterprise data and systems. Key threats include:

- Prompt injection and tool poisoning
- Data leakage from prompts and telemetry
- Excessive agent autonomy and lateral movement across systems
- Unauthorised access to sensitive data via tools and APIs
- Supply-chain risks from third-party MCP servers, plugins, and connectors
- Weak identity and authorisation for human, service, and agent principals

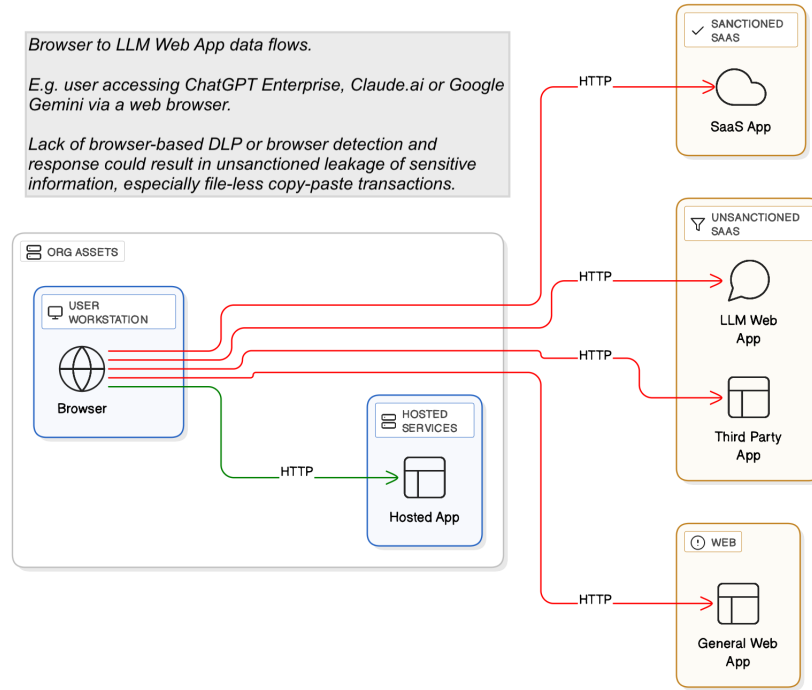


Figure 2: *Browser to LLM Web App data flow. E.g., user accessing ChatGPT Enterprise, Claude.ai or Google Gemini via a web browser.*

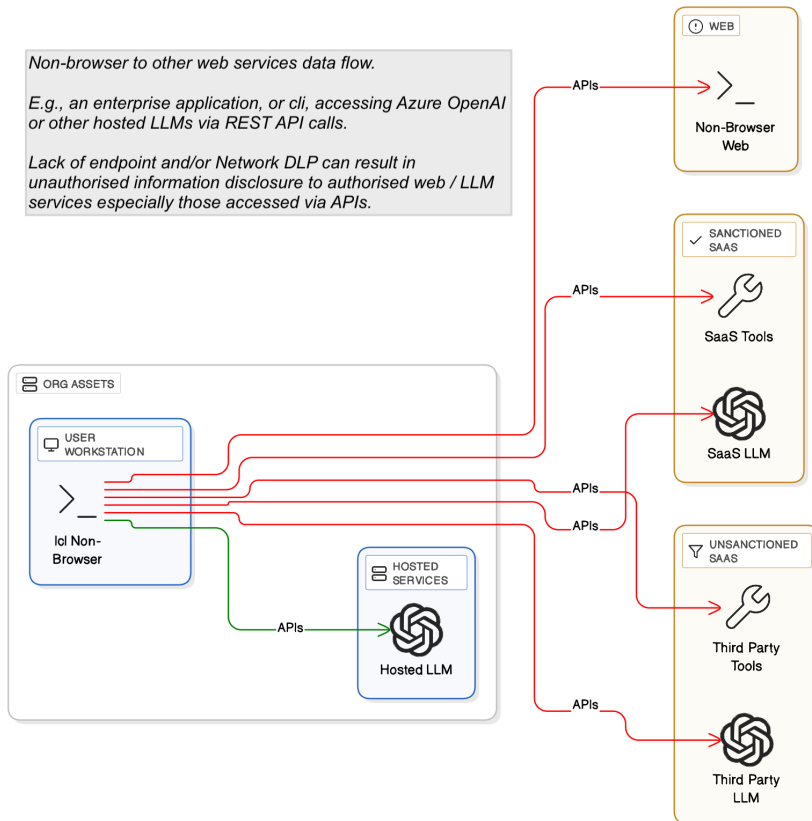


Figure 3: *Non-browser to other web services data flow. E.g., an enterprise application, or cli, accessing Azure OpenAI or other hosted LLMs via REST API calls.*

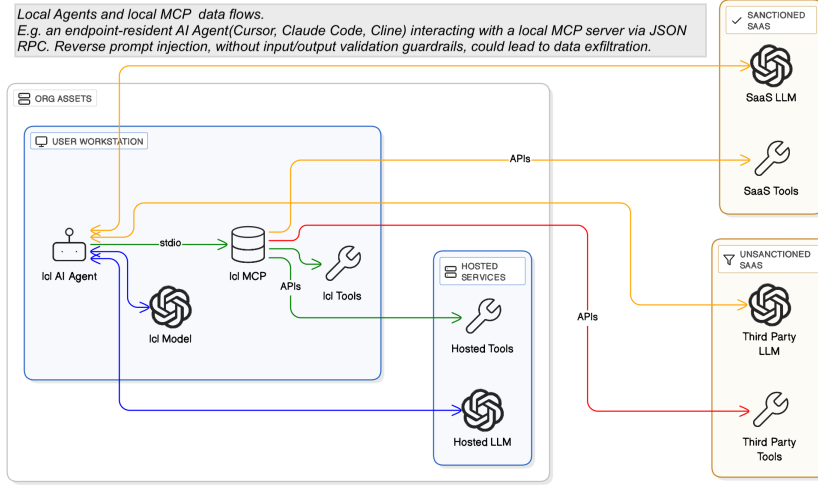


Figure 4: *Local Agent to local MCP server data flow. E.g., an endpoint-resident AI Agent (Cursor, Claude Code, Cline) interacting with a local MCP server via JSON RPC over stdio.*

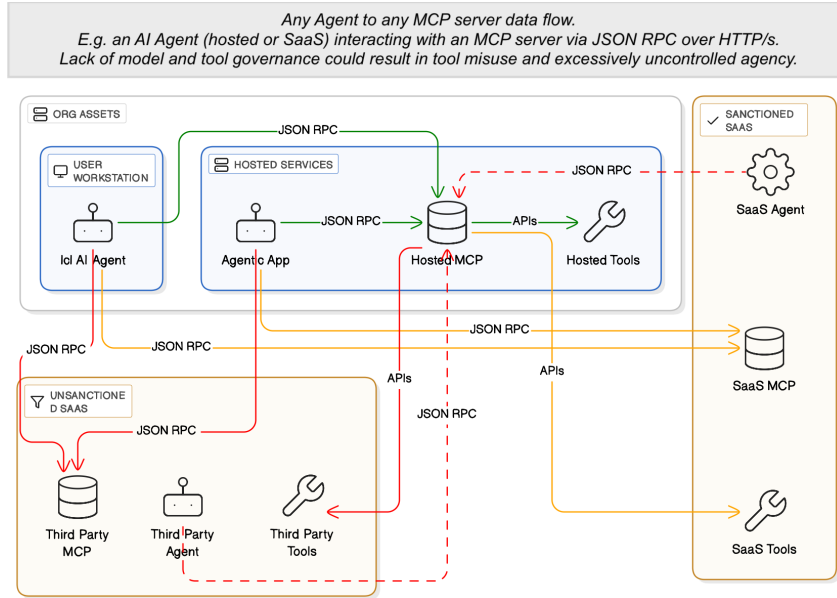


Figure 5: *Any Agent to any MCP server data flow. E.g., an AI Agent (hosted or SaaS) interacting with an MCP server via JSON RPC over HTTP/s.*

- Insufficient observability or incident response for AI-specific behaviours

Recent guidance emphasises risk-based controls across AI lifecycles and interface points, including NIST’s AI Risk Management Framework and related generative AI profiles, the updated OWASP Top 10 for LLM Applications (2025), and the emergence of interoperable agent standards and security frameworks such as Google’s Agent2Agent (A2A) protocol and the Agent-to-Agent Security (A2AS) framework for securing agent behaviour and communications [3, 16, 17, 20, 21, 25].

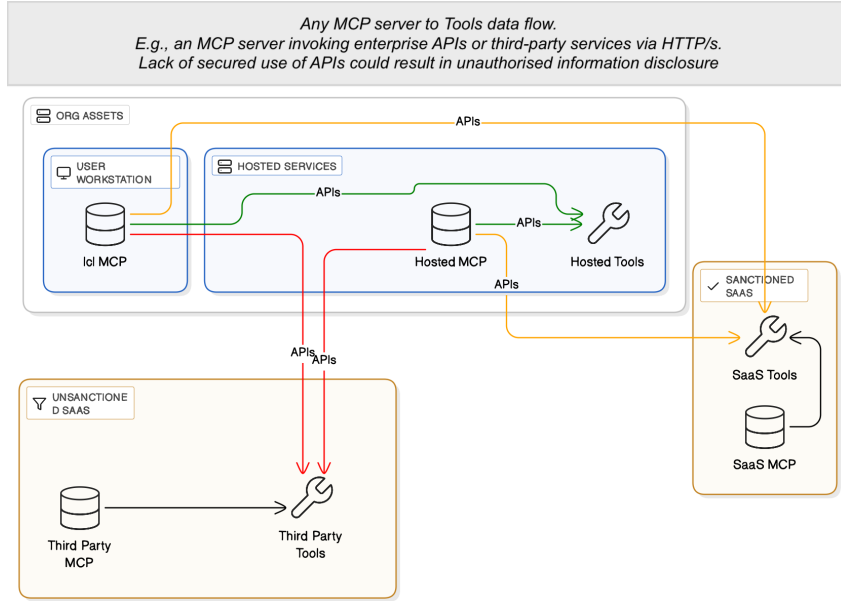


Figure 6: *Any MCP server to Tools data flow. E.g., an MCP server invoking enterprise APIs or third-party services via HTTP/s.*

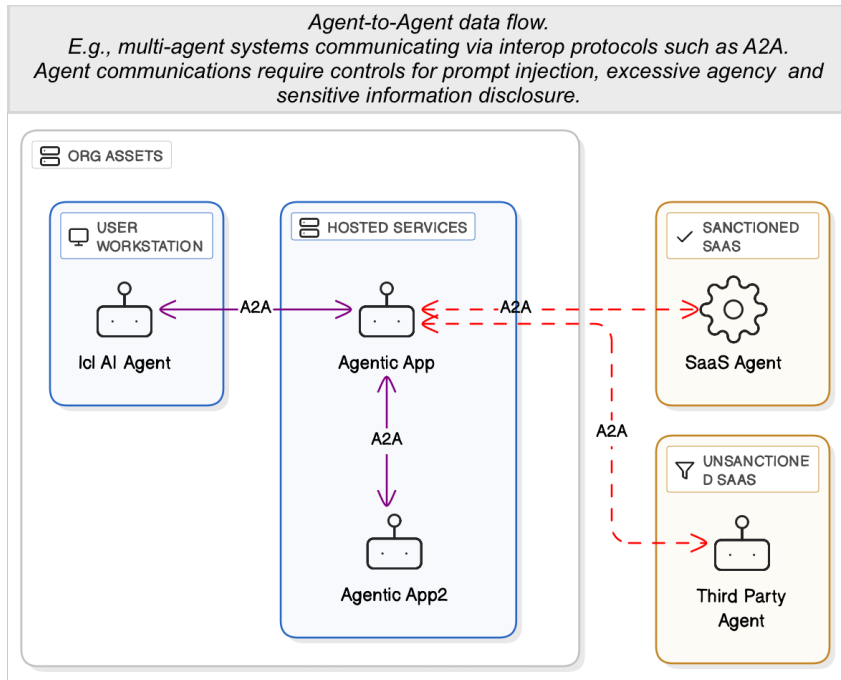


Figure 7: *Agent-to-Agent data flow. E.g., multi-agent systems communicating via interop protocols such as A2A.*

2. Reference Architecture Overview

The reference architecture is capability-based and vendor-agnostic. It comprises seven **control planes** that govern three **data planes** that carry sensitive flows.

2.1. Control planes

- **Identity & Access Management (IAM)**

Identity and AuthN/AuthZ: Unify human, workload, and agent identities; prefer short-lived credentials, token exchange, conditional access, and policy-as-code; scope tool permissions explicitly [15, 26, 27].

- **Data-centric Security**

Data security and privacy: Classification; tokenisation or format-preserving encryption; DLP; secret handling; content safety filtering at ingress and egress; protection of vector stores, caches, logs, and transcripts [6, 24].

- **Cloud & Infrastructure Security**

Network and segmentation: Private endpoints to hosted LLMs, controlled egress, and isolation for MCP servers and agent runtimes; explicitly brokered access to enterprise APIs [12, 14].

Orchestration and gateway: A central GenAI gateway authenticates users/services, enforces policy, routes to models, normalises observability, and abstracts providers / brokers enterprise APIs. [13].

- **Application & Automation Security**

Model and tool governance: Guardrails for prompts and outputs, tool allow-listing, red-team testing for jailbreaks and injections, safe function-calling conventions, and human-in-the-loop for high-risk actions. Align threat models and mitigations to the OWASP Top 10 for LLM Applications (2025), including controls for prompt injection, excessive agency, tool abuse, and sensitive information disclosure; when agents interoperate, adopt A2A-compatible identity and message integrity patterns and A2AS-style behavior certificates for runtime constraints [2, 3, 20, 21, 25].

Lifecycle and supply chain: Treat libraries, MCP servers, plugins, and connectors as supply-chain artifacts; threat-model updates, pin versions, harden build and deploy for orchestrators and agents [5].

- **Cyber SecOps and Resilience**

Observability and audit: Full-fidelity, privacy-preserving tracing across prompts, retrieved context, tool calls, MCP sessions, and API invocations; integration with SIEM/SOAR; principled access to sensitive logs [4, 14].

Testing and monitoring: Red-teaming for prompt injections, jailbreaks, tool poisoning, and cross-tenant data bleed; anomaly detection for tool usage and data volumes; incident response playbooks for AI-specific scenarios [9, 20, 21].

- **Governance, Risk & Compliance (GRC)**

Compliance and assurance. Map controls to NIST AI RMF, SP 800–53 overlays for AI, and enterprise regulations; verify SaaS/hosted guarantees such as “no training on business data” and encryption baselines [18, 19].

- **Endpoint Security**

Device posture and hardening: EDR/app control; full-disk encryption; OS keychain-managed secrets; local RAG with encrypted embeddings and revocation; local policy / rules to mediate tool permissions and MCP client behavior; egress proxy with DLP/CASB hooks; privacy-preserving local logging with central summaries [22, 24].

2.2. Data planes

Prompt and context plane: User inputs, system prompts, and retrieved knowledge (RAG and enterprise information assets).

Tool and action plane: Function calls, MCP tool invocations, and enterprise API transactions.

Telemetry and evidence plane: Logs, traces, model responses, safety events, and audit records.

3. Core Consumption Patterns and Prescribed Controls

3.1. Local LLM on enterprise endpoints

Pattern. Endpoint-resident runtime, optional local vector store, local tools, and brokered access to enterprise APIs through a managed proxy.

Controls. Device trust and hardening; EDR; full-disk encryption; OS keychain-managed secrets; short-lived tokens from a broker; local RAG with encrypted embeddings and revocation; a local policy agent to mediate tool permissions and MCP client behavior; egress proxy with DLP/CASB hooks; privacy-preserving local logging with central summaries [22, 24].

3.2. Hosted LLMs in a cloud tenancy

Pattern. A GenAI gateway authenticates users/services, injects policy, routes to hosted models in Azure OpenAI, mediates RAG integrations and vector stores, and brokers enterprise APIs.

Controls. Private endpoints, VNets / VPCs, managed identities; Key Vault/HSM; content filters and jailbreak detection at gateway and app layers; model routing by sensitivity and region; telemetry export to SIEM with privacy controls [4, 11, 12, 14].

3.3. Enterprise SaaS LLMs (e.g., ChatGPT Enterprise)

Pattern. SSO to a SaaS tenant, enterprise controls in the SaaS admin plane, secure connectors for retrieval, and a restricted tool ecosystem.

Controls. Validate vendor guarantees (no training on business data by default, encryption in transit and at rest, compliance posture); restrict and review connectors; scope data visibility; DLP at egress; integrate SaaS audit logs with enterprise monitoring; prefer an enterprise-controlled MCP bridge or vendor-approved plugins with scoped permissions [19].

4. Model Context Protocol (MCP) and Tool Security

MCP is a powerful but risky bridge from model suggestions to real actions. We recommend:

Strong identity and session binding. Where feasible, mTLS; OIDC-backed MCP clients; signed discovery; per-tool scopes; bind invocations to a human or service session and business context [26, 27].

Policy-as-code for tools. Central registry with allow-list, explicit parameters, preconditions, rate limits, and environment scoping per tool; explicit user consent for sensitive actions.

Input/output mediation. Normalise and validate tool inputs; taint-tracking across retrieved context; sanitise and sign tool outputs to bind them to the invocation and prevent replay.

Defenses against prompt injection and tool poisoning. Layered prompt hardening, server-side guardrails, and tool description linting; red-team for cross-server instruction conflicts and shadowing [7, 8, 10, 23].

Isolation and broker pattern. Run MCP servers in isolated sandboxes; terminate enterprise API access through an internal MCP-API broker that enforces authZ, performs data minimisation, masks secrets, and emits auditable traces.

Continuous monitoring. Per-tool anomaly detection on parameters, frequency, and data volumes; automated kill-switches [8, 23].

For multi-agent and cross-system orchestration, treat agent-to-agent links as high-risk trust boundaries. Where feasible, apply A2A-aligned discovery and authenticated exchanges, and bind agent capabilities to behaviour certificates as proposed by A2AS to prevent “excessive agency,” tool escalation, and cross-agent prompt-injection cascades. Tie each invocation to an authenticated principal and purpose, with signed message envelopes and replay protection [1–3, 21, 25].

5. GenAI Gateway: Policy and Observability Chokepoint

A GenAI gateway implements consistent security and governance across hosted and SaaS LLMs [13].

Capabilities. AuthN/AuthZ termination; content safety and PII redaction; DLP; model and route selection by sensitivity, geography, and cost; RAG mediation (source allow-list, query firewalling, result filtering, provenance tags); MCP mediation (tool registry, scope enforcement, audit); unified logging and cost controls; *agent and interop controls: verify A2A-style agent cards, enforce per-agent scopes, and validate A2AS behaviour certificates before allowing cross-agent actions* [1–3].

Benefits. Minimises lateral spread of sensitive data; normalises telemetry and incident response; decouples application teams from provider differences.

6. Data-Centric Security for Knowledge Retrieval and Telemetry

Classification and tagging. Propagate sensitivity in embeddings, context windows, and outputs; drive gateway policy by tags.

Minimisation and masking. Limit retrieval scope; prefer masked or tokenised data in prompts; reveal full values only in approved tools or APIs under policy.

Vector store hygiene. Encrypt embeddings; segment by tenant and purpose; support revocation and rebuilds.

Telemetry governance. Log sufficiently for investigation without leakage; partition access to raw prompts/results; apply safe sampling policies for any model improvement programs [22,24].

7. Identity, Authorisation, and Enterprise API Mediation

Human and service identities. SSO; device posture checks; conditional access; per-app consent; managed identities for hosted services.

Agent and tool identities. Treat agents as first-class non-human identities; scope their permissions with time-bound, task-bound credentials. For agent-to-agent workflows, require authenticated prompts and signed task exchanges consistent with A2A, and bind permissions to behaviour certificates (A2AS) that encode allowed resources, tools, and limits [2,3,25].

API gateways and brokers. Expose enterprise systems to AI tools only via an API gateway enforcing schema validation, PII minimisation, ABAC/ReBAC, and rate limits; log provenance including originating session and agent identity. [4,14].

8. Operations: Testing, Monitoring, and Incident Response

Red-teaming for GenAI. Systematically test for jailbreaks, indirect prompt injection via documents, tool poisoning, and cross-tenant data bleed. Include test suites aligned to the OWASP Top 10 for LLMs (2025) and agent interop threat scenarios (A2A), covering prompt-injection relays, cross-agent instruction conflicts, and message tampering [9,20,21].

Safety controls in CI/CD. Static and dynamic tests for prompts and tools; lint MCP tool manifests against enterprise policy.

Real-time risk controls. Anomaly detection for tool parameters and data volume; auto-quarantine agents or tools upon thresholds.

Incident response playbooks. Playbooks for compromised tool servers, unsafe content egress, and provider-side incidents.

Continuous assurance. Periodically validate SaaS claims and hosted posture against evolving NIST overlays and AI RMF profiles [17,18].

9. Anti-Patterns

- Blind trust in LLM outputs or agent autonomy without guardrails or human-in-the-loop for sensitive actions
- Direct database or system access from agents without a brokered API layer
- Unlimited retrieval scopes or embedding sensitive personal data without masking
- Tool registries without central policy, versioning, and attestation
- Verbatim logging of all prompts/outputs that becomes a parallel data-leak channel
- Cross-agent communication without authenticated prompts, signed envelopes, behavior certificates, or per-agent scopes (A2A/A2AS), resulting in excessive agency and unbounded lateral actions [3,21,25]

10. Implementation Roadmap - A Phased Approach

Phase 1: Foundations. Stand up a GenAI gateway for current use cases; inventory tools, connectors, MCP servers; enforce identity baselines and basic content safety.

Phase 2: Data-centric and tool mediation. Classify data and encrypt embeddings; introduce an API broker and MCP policy registry; onboard critical tools with allow-listing and guardrails.

Phase 3: Advanced governance. Establish red-team programs, jailbreak detection, and anomaly detection; map to NIST AI RMF and SP 800–53 overlays; validate SaaS posture and refine zero-trust networks.

11. Conclusion

Consumption-centric enterprise AI security hinges on controlling interfaces where LLMs touch business systems and data. A GenAI gateway, MCP/API mediation, strong identity, and data-centric protections secure the three dominant consumption models. Applying NIST-aligned governance, OWASP LLM Top 10 controls, A2A/A2AS-aligned interop security, continuous testing, and operational guardrails enables rapid AI adoption without compromising confidentiality, integrity, or compliance. [3, 16, 21, 25].

Future Work

Future research should explore sanitised deployment use case(s) on instantiating this reference architecture along with requisite security and operational controls including:

- Standardised MCP security profiles, automated behaviour certificate issuance for agents, and AI-specific incident response frameworks.
- Evolving best practices for supply-chain security in the AI ecosystem will also be critical as third-party MCP servers, plugins, and connectors proliferate.

Acknowledgments

The author thanks the security and AI engineering communities for evolving best practices in AI risk management, model safety, and enterprise controls.

References

- [1] A2A Project. Core concepts - a2a protocol, 2025. URL: <https://a2a-protocol.org/dev/topics/key-concepts>.
- [2] A2A Project. Key concepts - agent2agent protocol (a2a), 2025. URL: <https://google.github.io/A2A/topics/key-concepts/>.
- [3] A2AS Project. A2as: Standard for agentic ai security (agent-to-agent security framework), 2025. URL: <https://www.a2as.org/>.
- [4] Freddy Ayala. Security best practices for genai applications (openai) in azure, 2024. URL: <https://techcommunity.microsoft.com/blog/azurearchitectureblog/security-best-practices-for-genai-applications-openai-in-azure/4027885>.
- [5] Harold Booth, Murugiah Souppaya, Apostol Vassilev, Michael Ogata, Martin Stanley, and Karen Scarfone. Secure software development practices for generative ai and dual-use foundation models: An ssdf community profile. Technical report, National Institute of

- Standards and Technology, 07 2024. NIST SP 800-218A. URL: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-218A.pdf>.
- [6] Cloud Security Alliance. Securing llm backed systems: Essential authorization practices, 2025. URL: <https://cloudsecurityalliance.org/artifacts/securing-llm-backed-systems-essential-authorization-practices>.
- [7] Collabnix. Securing the model context protocol: A comprehensive guide, 2025. URL: <https://collabnix.com/securing-the-model-context-protocol-a-comprehensive-guide>.
- [8] GatewayMCP. Navigating the security landscape of the model context protocol (mcp), 2025. URL: <https://gatewaymcp.com/blog/security/navigating-the-security-landscape-of-the-model-context-protocol-mcp>.
- [9] Ken Huang and Idan Habler. Threat modeling google’s a2a protocol with the maestro framework, 04 2025. Cloud Security Alliance Blog. URL: <https://cloudsecurityalliance.org/blog/2025/04/30/threat-modeling-google-s-a2a-protocol-with-the-maestro-framework>.
- [10] iVision. Model context protocol: Security risks & solutions, 2025. URL: <https://ivision.com/blog/model-context-protocol-security/>.
- [11] Microsoft Architecture Center. Baseline azure ai foundry chat reference architecture (series), 2024. URL: <https://learn.microsoft.com/en-us/azure/architecture/ai-ml/architecture/baseline-openai-e2e-chat>.
- [12] Microsoft Architecture Center. Baseline azure ai foundry chat reference architecture in an azure landing zone, 2025. URL: <https://learn.microsoft.com/en-us/azure/architecture/ai-ml/architecture/azure-openai-baseline-landing-zone>.
- [13] Microsoft Learn. Designing and implementing a genai gateway solution, 2025. URL: <https://learn.microsoft.com/en-us/ai/playbook/solutions/generative-ai/genai-gateway/>.
- [14] Microsoft Learn. Get started with the azure openai security building blocks, 2025. URL: <https://learn.microsoft.com/en-us/azure/developer/ai/get-started-securing-your-ai-app?tabs=github-codespaces>.
- [15] Microsoft Learn. Security planning for llm-based applications, 2025. URL: <https://learn.microsoft.com/en-us/ai/playbook/technology-guidance/generative-ai/mlops-in-openai/security/security-recommend>.
- [16] NIST. Artificial intelligence risk management framework (ai rmf 1.0). Technical report, National Institute of Standards and Technology, 01 2023. NIST AI 100-1. URL: <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>.

- [17] NIST. Artificial intelligence risk management framework: Generative ai profile. Technical report, National Institute of Standards and Technology, 07 2024. NIST AI 600-1. URL: <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>.
- [18] NIST. Sp 800-53 control overlays for securing ai systems: Concept paper, 2025. Concept Paper. URL: <https://csrc.nist.gov/csrc/media/Projects/cosais/documents/NIST-Overlays-SecuringAI-concept-paper.pdf>.
- [19] OpenAI. Business data privacy, security, and compliance, 2025. URL: <https://openai.com/business-data>.
- [20] OWASP Foundation. Owasp top 10 for large language model applications, 2025. URL: <https://owasp.org/www-project-top-10-for-large-language-model-applications>.
- [21] OWASP GenAI Security Project. Owasp top 10 for llm applications 2025, 11 2024. Version 2025 (released Nov 18, 2024). URL: <https://owasp.org/www-project-top-10-for-large-language-model-applications/assets/PDF/OWASP-Top-10-for-LLMs-v2025.pdf>.
- [22] OWASP GenAI Security Project. Llm and gen ai data security best practices and related resources, 2025. URL: <https://genai.owasp.org/resource/llm-and-gen-ai-data-security-best-practices/>.
- [23] Protect AI. Mcp security 101: A new protocol for agentic ai, 2025. URL: <https://protectai.com/blog/mcp-security-101>.
- [24] Tobin South, Jules Drean, Abhishek Singh, Guy Zyskind, Robert Mahari, Vivek Sharma, Praneeth Vepakomma, Lalana Kagal, Srinivas Devadas, and Alex Pentland. A roadmap for end-to-end privacy and security in generative ai. *MIT GenAI*, 09 2024. URL: <https://mit-genai.pubpub.org/pub/m4msmss4/release/2>.
- [25] Rao Surapaneni, Miku Jha, Michael Vakoc, and Todd Segal. Announcing the agent2agent protocol (a2a), 04 2025. Developers Blog. URL: <https://developers.googleblog.com/en/a2a-a-new-era-of-agent-interoperability/>.
- [26] Teleport. Securing the model context protocol: Access, authorization, and audit for enterprise ai, 2025. URL: <https://goteleport.com/resources/white-papers/securing-mcp-access-authorization-audit-for-enterprise-ai>.
- [27] WorkOS. The complete guide to mcp security: How to secure mcp servers & clients, 2025. URL: <https://workos.com/blog/mcp-security-risks-best-practices>.